Mini project

Student Name
Razan Alshahrani
Team member 1
Team member 2
Team member 3
Team member 4

- **The TVA (Threat-Vulnerability-Asset) Matrix for SMC hospitals**

	Ranked Critical IT Resources (Most Critical to Least Critical)			
Ranked Threat Agents (most to least probable)	1. Patients DB	2. EMR System	3. Internal Network	4. Medical Devices
• Ransomware	,S6 ,S5 ,S3 ,S2 S10 ,S7	S1, S2, S3, S4, S5, S6, S7, S10	S1, S2, S3, S6, S10, S13	S1, S3, S6, S10, S11, S13
• Data breach	S1, S2, S4, S5, S6, S7, S9, S10, S13	S1, S2, S4, S5, S6, S7, S10, S13	S1, S2, S3, S4, S6, S10, S13	S1, S2, S4, S5, S12, S13
• Insider threat	S5, S6, S9, S10, S15, S16	S1, S2, S4, S6, S7, S10, S15, S16	S1, S2, S3, S5, S6, S10, S15, S17	S4, S6, S8, S9, S10, S13, S14
• IOMT Device Hijacking	S2, S10, S11	S2, S10, S12	S2, S3, S10, S13	S2, S3, S9, S11, S12, S13, S14
• Denial of Service Attack	S1, S2, S8 , S10	S1, S2, S8 , S10	S1, S2, S10	S1, S2, S8, S10 ، S11, S13, S14
Current IT Safeguards(Unranked)	S1: Firewall, S2: IDS/IPS, S3: Anti-malware, S4: Multi-Factor Authentication (MFA), S5: Encryption, S6: Security Training & Awareness (SETA), S7: Regular Backups, S8: UPS / Backup Power, S9: Physical Access Control, S10: Network Access Control (NAC),S11 :Device Authentication & Whitelisting, S12 :IoMT Firmware Updates, S13 :Medical Device Network Segmentation, S14 :Continuous IoMT Monitoring, S15: Network monitoring, S16:Least privilege principle, S17:Network segmentation.			

Extreme: Red, High: Orange, Moderate: Yellow, Low: Green

- **Justification for selecting the level of effect on the threat**

Threat / Asset	1. Patients DB	2. EMR System	3. Internal Network	4. Medical Devices
1. Ransomware	Ransomware on the patients' database removes the hospital's ability to "know" its patients. When information such as medical history, allergies, treatment history, lab results, and other clinical episodes becomes encrypted, clinicians must make decisions with significant blind spots. This drastically increases the risk of adverse and potentially fatal delays, especially in emergency and life-threatening situations. Because this asset directly affects the safety of all patient interactions, the consequences are considered Extreme.	The EMR system is more than a software platform; it is the hospital's operational rhythm. Every clinical action—recording vital signs, placing orders, dispensing medications, and viewing labs or radiology—relies on it. When ransomware locks the EMR, clinical activity does not merely slow; it collapses entirely. Departments lose coordination, orders cannot be processed, and documentation stops. The hospital becomes unable to function safely, which makes the consequence Extreme.	The internal network functions as the hospital's technological "circulatory system." Ransomware typically spreads by disrupting connectivity, isolating departments, and cutting off servers from one another. Even if individual apps are still operational, without network communications they are rendered useless. This results in a multipoint outage that causes significant operational disruption across major hospital systems. While these operational disruptions are severe, the network is not the direct target of encryption; rather,	Compromised medical devices pose serious risks by interrupting real-time monitoring and treatment. Devices may freeze, fail to transmit data, or stop reporting infusion or vital information to clinicians. However, the disruption is typically confined to specific devices rather than the entire infrastructure, and manual or backup equipment can often be used. For these reasons, the impact is High rather than Extreme.

			it is the channel through which the	
			ransomware spreads. For this reason, the impact on the internal network is classified as High.	

2. Data breach	A data breach exposes full patient records and causes permanent loss of confidentiality and trust. The impact cannot be reversed once the information is leaked and the organization faces direct legal and regulatory consequences. The effect is Extreme because the damage is permanent and directly affects patient privacy.	A breach of the EMR system exposes medical histories prescriptions and diagnostic information which disrupts clinical decisions and daily operations. The system can be restored after containment so the effect is High rather than permanent	A breach of the internal network exposes traffic credentials and configuration details. The impact is indirect because exposure does not immediately reveal complete patient data and can be contained through segmentation and access controls. The effect is Moderate.	A breach involving medical devices reveals limited operational data and can be resolved by isolating updating or resetting the device. It does not create permanent data loss or immediate clinical failure so the impact is Moderate.
3. Insider threat	Insider Threat represents an Extreme risk specifically to the Patient Database because insiders often hold elevated permissions that allow direct access to the stored patient data. If the system lacks strong security controls or does not enforce strict	Insider Threat poses a High risk to the EMR System because it contains and manages all core hospital operations, including patient records, treatment plans, medication orders, and clinical workflows. If an insider gains excessive access or misuses	Insider Threat is rated as Moderate for the Internal Network under the assumption that the network is properly segmented and protected by firewalls that prevent lateral movement between segments. Although an insider may still attempt to	Insider Threat is classified as an Extreme risk for Medical Devices because these systems perform highly sensitive and life-critical functions. Medical devices must be strictly protected and accessible only to authorized personnel with specialized technical

	least-privilege access, an insider can easily retrieve, alter, or disclose sensitive patient data. This makes the Patient Database highly vulnerable to insider misuse, positioning Insider Threat as one of the most severe risks affecting this asset.	operations , they can view, modify, or interfere with the hospital's operational data.	eavesdrop on network traffic or monitor internal communications, segmentation and access controls significantly limit the ability to modify or manipulate network resources. As a result, the insider's impact is mostly restricted to passive monitoring rather than active tampering, which places the overall risk at a Moderate level.	privileges. If an insider—even one with limited access—can modify configurations, alter operational settings, or interfere with device behavior, the consequences can directly affect patient safety and critical clinical outcomes. Due to the potential for severe and immediate impact, unauthorized insider access toMedical Devices represents one of the highestseverity risks, fully justifying an Extreme rating.
4. IOMT Device Hijacking	IoMT hijacking does not directly expose or corrupt patient records; it only disrupts the readings sent from devices. The risk is Moderate because clinical decisions may be delayed, but the database remains intact and no permanent data loss occurs.	Hijacked IoMT devices may send inaccurate or missing readings to the EMR, causing temporary confusion in patient charts. The risk is Moderate because the system itself is not compromised, and all EMR data remains recoverable once the device is secured.	A compromised IoMT device can be used as an access point to spread malware or disrupt communication inside the hospital. The risk is High because network slowdowns affect multiple departments, but it is not Extreme since services can be restored after	IoMT hijacking directly affects life-critical medical devices, allowing attackers to manipulate or disable them. The risk is Extreme because device failure can immediately endanger patient safety, and harm cannot be undone by simply restoring the network.

			isolating the device.	
5. Denial of Service Attack	DoS makes patient records inaccessible during emergencies, causing serious delays in treatment. Risk is high because patient safety is directly affected, but it is not Extreme since the data itself is not lost or corrupted; once service is restored, records remain intact.	Outage halts diagnosis and prescriptions, disrupting care severely. Risk is high due to the direct impact on medical decisions, but not Extreme because the disruption is temporary; once mitigated, the system resumes normally, unlike IoMT devices where failure can instantly endanger lives.	Network outage slows communication between departments but does not immediately stop patient care. Risk is moderate because the impact is indirect, and it is not High or Extreme since treatment continues with slower coordination rather than complete failure.	Disabling medical devices during use can interrupt lifesupport or drug delivery, endangering lives instantly. Risk is Extreme because survival depends directly on device availability, unlike databases or EMR where service can be restored without immediate fatal consequences.